MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D01

Project Foundation and Scenario Definition

Deliverable 1 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Project Foundation and Scenario Definition

MDM-D01

1. Purpose and Status

This document sets the foundation for the MDM GRC readiness assessment. It defines the business scenario, objectives, scope, assumptions and the method that links MDM-D02 to MDM-D15.

It describes how the assessment is performed, not what it found. Findings, gaps and readiness conclusions are reported in MDM-D10 to MDM-D14.

Simulation statement. The organization is fictional. No Microsoft Intune or Microsoft Entra ID tenant was configured. All evidence, test results, findings and readiness ratings in MDM-D09 to MDM-D14 are simulated and labeled as such. They show how the assessment would be performed and documented. They do not demonstrate that any control was implemented or operates effectively.

Source of the scenario. The starting scenario is adapted from a training exercise on mobile device risk: the company size, BYOD without MDM, and the four business problems. The risk method, control design, framework mapping, evidence model, test approach and all documents in this case study are my own work. MDM-D15 explains this split.

2. Business Scenario

The company is a fictional Saudi financing company with 850 employees. Staff use phones and tablets to read email, join meetings and work on documents away from their desks.

The company allows employees to use personal devices for work (BYOD) but has no mobile device management (MDM). It cannot see which devices hold corporate data, enforce protection on them, or remove that data when needed.

Management requested a readiness assessment after four recurring problems:

#	Business problem	Why it matters	Linked risk (MDM-D04)
1	Lost or stolen devices	Corporate email and documents stay on devices the company cannot lock or wipe.	MDM-RSK-001
2	Access not removed when people leave	Departed workers, including contractors, can keep reaching corporate data from their devices.	MDM-RSK-007
3	Devices not updated	Devices with outdated operating systems or security patches reach corporate services with known weaknesses.	MDM-RSK-003
4	Data copied to	Work documents move to personal apps and	MDM-RSK-

#	Business problem	Why it matters	Linked risk (MDM-D04)
	personal storage	cloud accounts outside company control.	002

Introducing MDM also creates risks of its own. MDM-D04 records four: disruptive access policy changes (MDM-RSK-004), unauthorized changes to device security settings (MDM-RSK-005), inappropriate access to employee device reports (MDM-RSK-006) and inaccurate compliance reporting (MDM-RSK-008).

The selected response is Microsoft Intune with Microsoft Entra ID: MDM enrollment for company-owned devices and app protection without enrollment for BYOD. Section 4 sets its boundaries.

3. Objectives

The assessment answers one question for management: is the company ready to run mobile access to corporate data under defined, testable controls? Six objectives support that answer.

ID	Objective	Achieved when	Shown in
OBJ-01	Define the mobile service, its assets and who is responsible.	Every in-scope asset has an ID and appears in the data flow. Every assessment activity has one accountable role.	MDM-D02, MDM-D03
OBJ-02	Assess the risks of the current state and of introducing MDM.	Every risk has a statement, linked assets, a risk owner and a score under one stated method.	MDM-D04
OBJ-03	Define control requirements and map them to recognized frameworks.	Every risk links to at least one control, and every control to a framework reference, a policy clause and a technical requirement.	MDM-D05, MDM-D06, MDM-D07, MDM-D08
OBJ-04	Define how each control is evidenced and tested.	Every tested control has an evidence request, a test procedure and a pass condition set before testing.	MDM-D09, MDM-D10
OBJ-05	Turn test results into gaps, remediation and risk treatment.	Every failed or partial test becomes a finding with a gap, an owner, a due date and a retest condition.	MDM-D11, MDM-

ID	Objective	Achieved when	Shown in
			D12
OBJ-06	Give management a readiness position and a decision to make.	The report states the overall risk level, the top three gaps, the immediate action, the owner and the decision required.	MDM-D13, MDM-D14

MDM-D15 summarizes the case study for a portfolio audience. It is not an assessment objective.

4. Scope and Exclusions

The assessment covers mobile access to Microsoft 365 from Android and iOS/iPadOS devices. This scope follows MDM-D06 Section 2, MDM-D07 Section 2 and MDM-D08 Section 1; where they differ, those documents govern.

In scope

Area	In scope	Source
Users	Employees on company-owned or approved personal devices; contractors on company-issued devices; Intune administrators.	MDM-D06, MDM-D08
Company-owned Android	Android Enterprise Fully Managed, associated with a single user.	MDM-D07
Company-owned iOS/iPadOS	Automated Device Enrollment, supervised, with user affinity.	MDM-D07
Personal devices (BYOD)	Android and iOS/iPadOS for eligible, approved employees, protected by Intune App Protection without MDM enrollment. Participation is voluntary.	MDM-D06, MDM-D07
Services	Microsoft 365 email, meetings, collaboration and work documents; Microsoft Intune; Microsoft Entra ID authentication and Conditional Access.	MDM-D03, MDM-D08
Information	Corporate documents accessed on mobile devices; employee device management reports.	MDM-D03
Activities	Administering the mobile service and handling employee device management reports.	MDM-D06

MDM-D03 lists the nine in-scope assets, MDM-AST-001 to MDM-AST-009.

Out of scope

Exclusion	Reason
Windows and macOS devices	Outside the permitted scope of the mobile service (MDM-D06, MDM-D08).
Core financing and payment operations from mobile devices	Not permitted on the mobile service (MDM-D06).
Privileged administrative sessions from mobile devices	Not permitted on the mobile service (MDM-D06).
Contractors on personal devices	Contractors must use company-issued devices (MDM-D07).
Guest and other external users	Governed by enterprise access policies (MDM-D08).
Design of user MFA	An enterprise policy the design depends on, not part of it (MDM-D08).
Live tenant configuration and testing	No tenant was configured; evidence and results are simulated (Section 5).

5. Assumptions and Constraints

The assessment rests on the assumptions below. Each one must be confirmed before the design is applied to a real organization. Technical assumptions specific to Conditional Access are listed in MDM-D08 Section 5.

Assumptions

ID	Assumption	Effect on the assessment
AS-01	The organization, its staff numbers and its roles are fictional.	Results illustrate the method, not a real environment.
AS-02	As a financing company, the company is regulated by SAMA. SAMA CSF v1.0 is the primary regulatory reference.	Control requirements in MDM-D05 map to SAMA CSF first.
AS-03	NCA ECC 2:2024 is adopted as an additional baseline for this case study.	Mappings show which controls support a provision, not full compliance. MDM-D05 records each mapping limitation.
AS-04	Microsoft 365 licensing covers Intune MDM,	Licensing and platform prerequisites

ID	Assumption	Effect on the assessment
	App Protection and Entra ID Conditional Access.	must be validated before implementation (MDM-D07 Section 2).
AS-05	An enterprise user MFA policy exists and covers this scope.	MFA design is excluded; its existence is confirmed with the IAM owner (MDM-D08).
AS-06	The roles in MDM-D02 exist and are staffed: CISO, GRC Analyst, IT Operations Manager and IT Operations Team. The Business Owner acts as Risk Owner, and Internal Audit retests work the GRC Analyst prepared.	Accountability in every deliverable depends on these roles.
AS-07	Platform behavior follows vendor documentation as checked at the time of writing.	Vendor changes may alter requirements; MDM-D10 tests confirm key platform assumptions.

Constraints

ID	Constraint	How it is handled
CN-01	No Intune or Entra ID tenant was configured.	All evidence and results in MDM-D09 to MDM-D14 are simulated and labeled as such.
CN-02	Not every requirement can be tested in one cycle.	MDM-D10 uses a risk-based sample of 10 tests and lists untested requirements with the reason.
CN-03	The GRC Analyst must stay independent of the operations being tested.	Operations staff perform operational activities such as access reviews; GRC tests them. Under MDM-CTL-005, the IT Operations Manager reviews team permissions and the CISO reviews the manager's.
CN-04	The project is prepared by one person without real stakeholder interviews.	Stakeholder input, approvals and evidence submissions are simulated.
CN-05	Framework references and vendor documentation change over time.	Each source is cited with its version, as in MDM-D05 and MDM-D08.

6. Approach and Traceability Chain

The assessment runs in six phases. Each phase uses the output of the one before it.

1. **Define**: set the scenario, scope, roles, assets and data flows (MDM-D01 to MDM-D03).
2. **Assess risk**: rate each risk under one method and assign a risk owner (MDM-D04).
3. **Design controls**: define control requirements, map them to frameworks, and turn them into policy, standard and access design (MDM-D05 to MDM-D08).
4. **Evidence and test**: request evidence and test a risk-based sample of controls (MDM-D09, MDM-D10).
5. **Remediate**: record findings, gaps and recommendations, then treat and retest the risks (MDM-D11, MDM-D12).
6. **Report**: track readiness and give management a decision (MDM-D13, MDM-D14).

Traceability chain

Every item links to the item before it by ID. A reader can start from any asset and follow it to a management decision, or start from a decision and trace it back.

Link	What it records	ID format	Recorded in
Asset	A device group, service or information set in scope	MDM-AST-001	MDM-D03
Risk	What could go wrong, to which assets, and who owns it	MDM-RSK-001	MDM-D04
Control	The requirement that treats the risk, with its framework mapping	MDM-CTL-001	MDM-D05 (policy in MDM-D06, technical requirements in MDM-D07, access policies MDM-CAP-001 in MDM-D08)
Evidence	What must be produced to show the control works	MDM-EVD-001	MDM-D09
Test	How the control is tested and what counts as a pass	MDM-TST-001	MDM-D10
Finding and gap	Current state, required state, the gap and the resulting risk	MDM-FND-001	MDM-D11
Recommendation	Action, owner, due date and success measure	MDM-REC-001	MDM-D11, MDM-D12
Decision	What the Risk Owner or	D-01	MDM-D11 Section

Link	What it records	ID format	Recorded in
	management must decide or accept		6, MDM-D12 Section 3, MDM-D14 Section 6

Chain rules

- Each record cites the ID of the link above it. A record with no upstream link is flagged as a gap in traceability, not dropped.
- A control without a test is listed in MDM-D10 as untested, with the reason.
- Every simulated evidence item and test result is labeled as simulated.
- Deliverable IDs (MDM-D01 to MDM-D15) are fixed and never reused.

7. Deliverables Map

The case study has 15 deliverables. The last column shows which of the eight outputs of the original exercise each one covers; each of those eight can be read on its own.

ID	Deliverable	Phase	Purpose	Exercise output
MDM-D01	Project Foundation and Scenario Definition	Define	Scenario, objectives, scope, assumptions and method.	Scope (Section 4)
MDM-D02	Stakeholder and RACI Matrix	Define	Who is responsible and accountable for each assessment activity.	—
MDM-D03	MDM Data Flow and Asset Inventory	Define	In-scope assets and how corporate data moves between them.	Asset inventory
MDM-D04	Risk Assessment Methodology and Risk Register	Assess risk	Scoring method and the eight risks with owners.	Risk register
MDM-D05	Control Requirements and Framework Crosswalk	Design controls	Controls that treat each risk, mapped to SAMA CSF and NCA ECC.	Control matrix
MDM-D06	Mobile Device and BYOD Policy	Design controls	Rules and responsibilities for corporate and personal devices.	—
MDM-D07	MDM Security	Design	Verifiable technical	—

ID	Deliverable	Phase	Purpose	Exercise output
	Standard	controls	requirements per platform and model.	
MDM-D08	Conditional Access Control Design	Design controls	Access policies that enforce device and app requirements.	—
MDM-D09	Evidence Request List and Evidence Index	Evidence and test	What evidence each control needs and who provides it.	Evidence list
MDM-D10	Control Testing Workbook	Evidence and test	Test procedures, pass conditions and simulated results.	—
MDM-D11	Findings and Remediation Register	Remediate	Findings, gap analysis, recommendations and decisions required.	Gap analysis; Recommendations
MDM-D12	Risk Treatment and Retesting Record	Remediate	Residual risk, treatment decisions and retest plan.	Recommendations (follow-up)
MDM-D13	GRC Workspace and Readiness Dashboard	Report	Readiness measures, status and escalation.	—
MDM-D14	Executive Readiness Report	Report	The readiness position and the decision required from management.	Executive summary
MDM-D15	Portfolio Case Summary and LinkedIn Presentation	Portfolio	A short account of the case study and of what is my own work.	—